FROM GOOGLE AI STUDIO POC TO ANTIGRAVITY ENTERPRISE RC

Assurance, Self-Auditing & GenAI FinOps Economics

How **AegisAI Enterprise** was prototyped in **Google AI Studio (Gemini 3.8 to 3.6 Flash)**, engineered in **Google Antigravity (Gemini 3.8 Flash)**, self-audited against **OWASP AI-SVS v1.0 & ISO/IEC 42001:2023** (68.9% ➔ 97.8%), and presented as a Release Candidate to **Farmacias del Ahorro**, **Asociación Mexicana de Franquicias**, and **Grupo Coppel**—for a total build cost of **$19.41 USD**.

1. AI STUDIO POC (GEMINI 3.8–3.6 FLASH)
2. ANTIGRAVITY FULL-STACK BUILD (3.8 FLASH)
3. SELF-AUDIT LOOP: 68.9% ➔ 97.8%
4. RC: FARMACIAS DEL AHORRO • AMF • COPPEL
5. AUDIT COST: $0.08–$0.30 VS $8.55–$31.09
6. TOTAL APP BUILD COST: $19.41 USD

END-TO-END ENGINEERING LIFECYCLE

How We Built, Self-Audited, and Validated AegisAI

A four-stage agentic software engineering journey from rapid concept validation to enterprise release candidate.

PHASE 1 • PROOF OF CONCEPT

1. Prototyped in Google AI Studio (Gemini 3.8 to 3.6 Flash)

• Built the initial Proof of Concept in **Google AI Studio** using **Gemini 3.8 Flash** with automatic fallback to **Gemini 3.6 Flash**.
• Validated structured JSON Schema output generation, multi-chapter normative reasoning, and initial React UI scaffolding.
• Proved that Flash-class models with strict system instructions and temperature `0.0` could evaluate complex security controls rapidly.

PHASE 2 • FULL-STACK ENGINEERING

2. Migrated to Google Antigravity (Worked Upon with 3.8 Flash)

• Transitioned the repository into **Google Antigravity (AGY)** powered by **Gemini 3.8 Flash**.
• Executed **171+ conversational engineering prompts** across 7 structured phases to build the Express/TypeScript backend, parallel Map-Reduce evaluator, keyless GCP Live Scanner, multi-tenant Firestore persistence, and 16 bilingual PDF manuals.
• Deployed to Google Cloud Run behind Identity-Aware Proxy (IAP).

PHASE 3 • DOGFOODING & HARDENING

3. Self-Audited Codebase & Docs Against AegisAI Itself

• Once the working prototype was live on Cloud Run, we uploaded **AegisAI's own codebase and 10-PDF documentation bundle (`Originaldocs.zip`)** into AegisAI to run a full **OWASP AI-SVS v1.0 + ISO/IEC 42001:2023** audit.
• Baseline self-audit (`MULTI-2026-0437`) scored **68.9%** and flagged 35 gaps (6 Failed, 29 Missing Evidence).
• We fixed both the documentation and the application, re-auditing at **97.8%** (`MULTI-2026-8983` , **100% ISO 42001**, 0 failures).

PHASE 4 • ENTERPRISE FIELD VALIDATION

4. Release Candidate (RC) Presented to Industry Leaders

• Presented the hardened Release Candidate (RC) to three major Mexican organizations:
1. **Farmacias del Ahorro** (Healthcare & Retail Pharmacy)
2. **Asociación Mexicana de Franquicias (AMF)** (Franchise Ecosystem)
3. **Grupo Coppel** (Financial Services & Omnichannel Retail)

• Validated multi-standard compliance (OWASP AI-SVS, ISO 42001, LFPC & LFPDPPP).

EATING OUR OWN DOGFOOD

Running AegisAI's Codebase & Documentation Against Itself

How AegisAI diagnosed 35 OWASP AI-SVS & ISO 42001 gaps in its own prototype and guided its own remediation to 97.8%.

1. Baseline Self-Audit (`MULTI-2026-0437`)

- **Overall Score: 68.9% (Level L2)**
- **OWASP AI-SVS v1.0:** 71.8% (17 gaps)
- **ISO/IEC 42001:2023:** 66.7% (18 gaps)
- **Key Findings Detected by AegisAI:**
  - Writable `/app/config` in container (`C04.1`)
  - Timing-vulnerable token check `===` (`C05.3`)
  - Legacy `roles/viewer` on runtime SA (`C05.2`)
  - Missing SHA-256 normative manifest (`C01.4`)
  - Missing ISO 42001 AIMS Policy & Appeal docs

2. Full-Stack Remediation in Antigravity

- **Generator Fixes:** Untruncated Section 4 Cookbook (all 35 patches), smart sentence-boundary splitter, accurate syntax tags.
- **Container & Cloud:** `chmod -R a-w /app` (`C04.1`), Cloud IAP + SSRF/IMDS blocker (`C04.3`), pruned `roles/viewer` (`C05.2`).
- **Runtime Guardrails:** SHA-256 manifest (`C01.4`), crescendo detector (`C02.10`), `crypto.timingSafeEqual` (`C05.3`), Anti-DoW quotas (`C11.1`), sagas (`C09.4`).
- **Docs & Rules:** Authored Manual 8 (ISO 42001 AIMS) & passed 308/308 Firestore rules unit tests.

3. Post-Fix Re-Audit (`MULTI-2026-8983`)

- **Overall Score: 97.8% (+28.9 pts)**
- **ISO/IEC 42001:2023: 100.0%** (54/54 mandatory passed, **0 Failed**)
- **OWASP AI-SVS v1.0: 94.7%** (45/49 passed, **0 Failed**)
- **Telemetry Recorded in Firestore:**
  - Model: `gemini-3.8-flash` on Vertex AI
  - Input Tokens: `1,758,724`
  - Output Tokens: `100,715`
  - Zero critical or high-risk failures remaining

Why Self-Auditing Matters: Running AegisAI against its own architecture and manuals proved that the evaluator does not hallucinate approvals—it caught subtle issues (such as `providedToken === configuredToken` and missing ISO 42001 whistleblowing/appeal channels) and verified their closure once remediated.

MARKET VALIDATION & EXECUTIVE ROADSHOW

Release Candidate (RC) Presented to Strategic Enterprises

Following our self-audit hardening loop, the AegisAI Release Candidate was presented to three flagship Mexican organizations.

HEALTHCARE & RETAIL PHARMACY

Farmacias del Ahorro

- **Use Case Focus:** Auditing clinical/pharmacy digital assistants, prescription triage bots, and omnichannel customer service AI.
- **Key AegisAI Capabilities Demonstrated:**
  - Strict **LFPDPPP** sensitive health/PII data protection & pre-inference DLP masking.
  - Hallucination prevention (`temperature: 0.0`) and human escalation workflows (`ISO 42001 A.5.2`).
  - Continuous RAG grounding telemetry (`C08.4`) on Google Cloud Vertex AI.

NATIONAL FRANCHISE ECOSYSTEM

Asociación Mexicana de Franquicias

- **Use Case Focus:** Standardizing AI adoption, customer chatbots, and automated marketing compliance across hundreds of member franchises.
- **Key AegisAI Capabilities Demonstrated:**
  - **LFPC (Profeco 2026)** compliance: preventing deceptive AI commercial patterns and enforcing Art. 56 5-day cooling-off retraction.
  - **BYOF Engine:** Custom franchise governance templates with low-cost Flash evaluations (`$0.08/audit`).

FINANCIAL SERVICES & RETAIL

Grupo Coppel

- **Use Case Focus:** High-scale credit scoring ML, fraud detection engines, and enterprise GenAI engineering governance.
- **Key AegisAI Capabilities Demonstrated:**
  - Simultaneous **OWASP AI-SVS v1.0 (Level L2/L3) + ISO/IEC 42001:2023** certification readiness.
  - Multi-tenant domain isolation (`C05.4` , `C08.1`), Cloud IAP Zero-Trust perimeter, and keyless **GCP Live Scanner**.
  - Drop-in remediated architecture & Terraform/TypeScript cookbook generation.

Executive Feedback Highlights: Enterprise stakeholders highlighted AegisAI's ability to combine **global technical standards (OWASP AI-SVS + ISO 42001)** with **Mexican statutory law (LFPDPPP + LFPC)** while delivering ready-to-deploy remediation code at a fraction of traditional consulting costs.

FINOPS ANALYSIS: COST PER COMPLETE OWASP AI-SVS + ISO/IEC 42001 AUDIT

Gemini (3.8 Flash, 3.1 Pro, 4.0 Argon) vs. Claude (Fable 5.1, Opus 5.5)

Calculated from real production Firestore token telemetry across 12 Map-Reduce LLM calls per full dual-standard audit.

Model Tier	API Rate Card (Input / Output per 1M tok)	Standard Audit Cost (370K In + 40K Out tok)	Full 10-PDF Bundle Audit (1.64M In + 86.5K Out tok)	Cost Multiplier vs. Gemini 3.8 Flash
Gemini 3.8 Flash PRODUCTION	`$0.15` / `$0.60`	**$0.08 USD** ($0.0795)	**$0.30 USD** ($0.2979)	1.0X (BASELINE)
Gemini 3.1 Pro	`$1.25` / `$10.00`	**$0.86 USD** ($0.8625)	**$2.92 USD** ($2.9150)	9.8X – 10.8X
Gemini 4.0 Argon FRONTIER	`$2.00` / `$12.00`	**$1.22 USD** ($1.2200)	**$4.32 USD** ($4.3180)	14.5X – 15.3X
Claude Fable 5.1 Medium	`$3.00` / `$15.00`	**$1.71 USD** ($1.7100)	**$6.22 USD** ($6.2175)	20.9X – 21.5X COSTLIER
Claude Opus 5.5 Max	`$15.00` / `$75.00`	**$8.55 USD** ($8.5500)	**$31.09 USD** ($31.0875)	104.4X – 107.5X COSTLIER

Real Telemetry Basis (Firestore)

- **Standard Audit** (`MULTI-2026-0507` / `1250`): Avg `368,827` input + `39,812` output tokens.
- **Full 10-PDF ZIP Audit** (`MULTI-2026-0437` / `8983`): Avg `1,638,410` input + `86,495` output tokens across 12 batch calls (~136K context/call).

Annual FinOps @ 1,000 Audits/Yr

- **Gemini 3.8 Flash: $298 / year** (Full ZIP) or **$80 / yr** (Std)
- **Gemini 3.1 Pro: $2,915 / year**
- **Gemini 4.0 Argon: $4,318 / year**

Competitor Spend @ 1,000 Audits/Yr

- **Claude Fable 5.1 Medium: $6,218 / year** (21x higher)
- **Claude Opus 5.5 Max: $31,088 / year** (104x higher)
- **Savings with Gemini 3.8 Flash: >99% cost reduction**.

Telemetry Source: Cloud Firestore (aegis-ai-db) Audits MULTI-2026-0437, 8983, 0507 & 1250

ENGINEERING ROI & DEVELOPMENT COST BREAKDOWN

How Much Money We Spent Creating AegisAI: $19.41 USD Total

Complete accounting of all AI token consumption and Google Cloud infrastructure from initial AI Studio PoC to Enterprise RC.

$19.41
Total Money Spent creating AegisAI (AI Tokens + GCP Infra)

~71.0M
Total Input Tokens across AI Studio, Antigravity (171+ prompts) & Self-Audits

$1,928
What the exact same token volume would have cost on **Claude Opus 5.5 Max**

~$95,000
Equivalent traditional engineering cost (4 DevSecOps engineers × 3 months)

Development Phase	Platform & Model Used	Volume / Activity	Actual Spend	If Run on Opus 5.5
1. Proof of Concept (PoC)	Google AI Studio (`Gemini 3.8–3.6 Flash`)	~45 iterations • ~4.2M In / ~0.9M Out tokens	**$1.17 USD**	$130.50 USD
2. Core Full-Stack & Manuals (Phases 1–7)	Google Antigravity (`Gemini 3.8 Flash`)	171 logged prompts + 16 PDFs • ~38.0M In / ~6.5M Out	**$9.60 USD**	$1,057.50 USD
3. Cloud Hardening & OWASP/ISO Fixes	Google Antigravity (`Gemini 3.8 Flash`)	Argolis IAP, 308 rules tests, 35 controls • ~24.0M In / ~3.8M Out	**$5.88 USD**	$645.00 USD
4. Live Self-Audits & QA Test Harnesses	Vertex AI (`Gemini 3.8 / 3.1 Flash`)	`MULTI-2026-0437` , `8983` , `0507` , `1250` • ~4.8M In / ~0.32M Out	**$0.91 USD**	$96.00 USD
5. Google Cloud Infrastructure	Cloud Build, Cloud Run, Firestore, Secret Mgr	9 container builds, scale-to-zero runtime, `aegis-ai-db`	**$1.85 USD**	$1.85 USD

99.0% Savings vs. Claude Opus 5.5 Max • 99.98% Savings vs. Traditional Software Staffing

THE PROBLEM TO SOLVE

The Critical Security Blindspot in Enterprise GenAI Adoption

Enterprises are shipping generative AI models, agentic workflows, MCP tools, and RAG pipelines without architectural verification or ISO 42001 governance.

⚠ Ungoverned AI Access & Breaches

Per **IBM Cost of a Data Breach 2025**, **13% of organizations** reported breaches of AI models or applications, and **97% of those** lacked proper AI access controls or formal impact assessments (`ISO 42001 A.5.1`).

⚠ Multi-Turn & Agentic Attack Surface

RAG pipelines, MCP servers, and autonomous agents introduce critical vectors: **Multi-Turn Crescendo Prompt Injection** (`C02.10`), **Normative/Vector Poisoning** (`C01.4`), and SSRF/IMDS exfiltration (`C04.3`).

⚠ CISO vs Data Science Silo

Security teams lack tools to audit agent graphs, MCP manifests (`C10.1`), and pre-retrieval vector ACLs (`C08.1`); AI developers lack automated mappings to formal compliance clauses.

Lack of Operationalized Governance (ISO/IEC 42001)

Organizations struggle to operationalize **ISO/IEC 42001:2023** requirements—such as Corporate AI Policies (`A.2.1`), Confidential Whistleblowing (`A.3.3`), AI Asset Inventories (`A.4.1`), and Human Verdict Appeals (`A.5.2`)—into software engineering workflows.

Proliferation of "Shadow AI" & Denial of Wallet

Unregulated external API calls, timing-vulnerable token checks (`C05.3`), over-privileged service accounts (`C05.2`), missing Anti-DoW token budgets (`C11.1`), and exposed logit probabilities (`C11.4`).

Source: OWASP GenAI Security Project (AI-SVS v1.0) & ISO/IEC 42001:2023

COMPLIANCE MATRIX

Multi-Standard Framework Support & ISO/IEC 42001 AIMS

Simultaneous evaluation across global technical security standards, management systems, and regional privacy statutes.

Standard / Framework	Technical & Governance Scope	Key Controls Verified & Enforced by AegisAI	Assurance Level
OWASP AI-SVS v1.0	AI Security Verification Standard (12 Chapters)	`C01.4` SHA-256 Manifest, `C02.10` Crescendo Guard, `C04.1` Read-Only Container, `C04.3` Cloud IAP & SSRF Block, `C05.2–C05.4` Constant-Time Auth & IAM, `C08.1/C08.4` RAG ACLs, `C09.4` Sagas, `C10.1–C10.5` MCP Security, `C11.1/C11.4` Anti-DoW & Logprobs Off, `C12.2` SIEM Alerts.	L1 / L2 / L3 READY
ISO/IEC 42001:2023	AI Management System (AIMS Clauses 4–10 & Annex A)	`Clause 4.1/4.2` Context & Stakeholders, `Clause 5/A.2.1/A.2.3` Corporate AI Policy, `Clause 7/A.3.3` Competency & Whistleblowing, `A.4.1` AI Asset Inventory, `A.5.1–A.5.3` Impact Assessment & Human Appeal, `Clause 9` KPIs & Internal Audit, `A.9.1/A.9.2` Acceptable Use.	CERTIFICATION READY
Mexican Regulatory (2026)	Consumer Protection (LFPC) & Personal Data (LFPDPPP)	Algorithmic transparency, deceptive commercial pattern prevention, Art. 56 5-day cooling-off retraction, ARCO cascading deletion, and DLP PII masking.	REGIONAL STATUTORY
BYOF Custom Framework	*Bring Your Own Framework* (Multi-Tenant)	Admin-authenticated ingestion (`C05.3`) with SHA-256 integrity checks (`C01.4`) and pre-retrieval tenant domain ACL filtering (`allowedDomains` , `C08.1`).	TENANT ISOLATED

Unified Cross-Framework Map-Reduce: Evaluates 103+ combined OWASP AI-SVS & ISO/IEC 42001 controls in parallel batches using constrained chapter ID enums so ISO Clauses 9/10 and Annex A.9/A.10 never collide with OWASP C09/C10.

SOFTWARE ARCHITECTURE

4-Layer Zero-Trust & Defense-in-Depth Architecture

Hardened serverless architecture deployed on Google Cloud Run behind Identity-Aware Proxy (IAP) with keyless Vertex AI inference.

1. Perimeter & SPA

- **Cloud IAP** (`--no-allow-unauthenticated`)
- **React 19 + TS + Vite**
- Firebase Auth OAuth 2.0 domain allowlist (`google.com` , `altostrat.com`)
- Embedded ISO 42001 Policy, Appeal (`A.5.2`) & Whistleblowing (`A.3.3`) UI

2. Hardened API Layer

- **Read-Only Container** (`chmod -R a-w /app` , `C04.1`)
- Constant-time token check (`crypto.timingSafeEqual` , `C05.3`)
- Firebase Admin `verifyIdToken()`
- DNS Rebinding Guard (`C10.5`) & MCP Signature Verifier (`C10.1`)
- Anti-DoW Quotas (`C11.1`)

3. AI Engine & Guardrails

- **Vertex AI** (`gemini-3.8-flash`) via keyless ADC
- Least-privilege SA (`aegis-runner-sa` : zero `roles/viewer` , `C05.2`)
- Multi-Turn Crescendo Detector (`C02.10`)
- `responseLogprobs: false` (`C11.4`)
- Outbound SSRF/IMDS Block (`C04.3`)

4. Data, Integrity & Sagas

- **Cloud Firestore** (`aegis-ai-db`) via Admin SDK
- 308/308 tested `firestore.rules`
- Immutable audits (`allow delete: if false`) & `ownerUid` ACLs (`C05.4`)
- SHA-256 Manifest (`C01.4`)
- Compensating Sagas (`C09.4`)

Zero-Trust Isolation & Structured Security Alerting (C12.2):

Runtime state writes exclusively to Firestore (`system_config/admin_settings`) and ephemeral `/tmp/aegis-runtime-cache` . Every security event (prompt injection escalation, SSRF block, token mismatch, DoW quota breach, saga rollback) emits a structured JSON alert (`aegis-security-alerting-c12-2`) to Google Cloud Logging.

OPERATIONAL EXECUTION

The Auditor's Workflow: From Ingestion to 100% Hardening

Six-stage deterministic assurance lifecycle with built-in human oversight and automated code remediation.

1 Authenticated Ingestion & Pre-Flight Guardrails
Corporate user (verified via Cloud IAP + Firebase ID Token) uploads PDFs/ZIPs/specs; `inspectPromptAndTrackSession` (`C02.10`) and DLP masking sanitize input.

2 SHA-256 Verified & Tenant-Filtered Context
Normative snapshots verified against `integrity-manifest.json` (`C01.4`) and custom frameworks filtered by `tenantDomain` (`C08.1`) are loaded.

3 Deterministic Vertex AI Map-Reduce Evaluation
`gemini-3.8-flash` (`temperature: 0.0` , `responseLogprobs: false` , 180s timeout) evaluates each batch under strict chapter enum schemas.

4 Executive Dashboard & Human Appeal (ISO A.5.2)
Interactive radar charts, L1/L2/L3 maturity breakdown, and direct Verdict Appeal / Human Review workflow (`ai-appeals@aegisai.enterprise`).

5 100% Remediated Architecture & Full Cookbook
Synthesizes Section 3 drop-in architecture + Section 4 Cookbook for all `1..N` findings with accurate syntax tags (`typescript` , `hcl` , `yaml` , `python` , `bash`).

6 Immutable Persistence & Compensating Saga
Saved to Firestore with `ownerUid` / `tenantDomain` attribution (`C05.4`), `runCompensatingSaga` rollback safety (`C09.4`), and AIMS KPI recording (`C08.4`).

END-TO-END REMEDIATION TRACEABILITY

OWASP AI-SVS v1.0 & ISO/IEC 42001:2023 Controls Enforced

Comprehensive architectural and governance controls implemented across code, container, cloud perimeter, and AIMS policies.

OWASP AI-SVS v1.0 Technical Controls (17 Hardened Domains)

- **C01.4 Normative Integrity:** `verifyNormativeSnapshotsIntegrity()` SHA-256 manifest check at startup.
- **C02.10 Crescendo Defense:** `inspectPromptAndTrackSession()` multi-turn escalation blocker (HTTP 422).
- **C04.1 & C04.3 Infrastructure:** Read-only `/app` (`chmod -R a-w`), Cloud IAP, VPC egress & `validateOutboundEndpoint()` SSRF/IMDS block.
- **C05.2, C05.3 & C05.4 Auth/IAM:** Pruned `roles/viewer` on `aegis-runner-sa` , `crypto.timingSafeEqual` , Firebase ID token verification & Firestore `ownerUid` ACLs.
- **C08.1 & C08.4 RAG/Grounding:** Tenant domain ACL pre-filtering & continuous grounding telemetry.
- **C09.4 & C10.1–C10.5 Agents/MCP:** `runCompensatingSaga()` rollback, MCP Ed25519/HMAC manifest verification, OAuth 2.1 PKCE & `dnsRebindingGuard` .
- **C11.1, C11.4 & C12.2 FinOps/SIEM:** `acquireAntiDoWQuota()` , `responseLogprobs: false` & `emitSecurityAlert()` .

ISO/IEC 42001:2023 AIMS Governance Controls (18 Clauses & Annex A)

- **Clause 4.1 & 4.2 Context & Stakeholders:** Formal internal/external issue matrix, societal role as AI assurance provider & stakeholder mapping.
- **Clause 5.1, 5.2, A.2.1 & A.2.3 Leadership & AI Policy:** Executive-approved Corporate AI Policy with annual revision cycle.
- **Clause 7.2, 7.3 & A.3.3 Competency & Whistleblowing:** Mandatory role training & confidential ethics reporting (`ai-ethics-whistleblower@aegisai.enterprise`).
- **A.4.1 Resource & Tooling Inventory:** Cataloged models, normative corpora, runtime SAs & KMS secrets.
- **A.5.1, A.5.2 & A.5.3 Impact Assessment & Appeals:** Formal AIIA methodology, quantitative risk thresholds & human appeal channel (`ai-appeals@aegisai.enterprise`).
- **Clause 9.1–9.3 & A.9.1/A.9.2 Assurance & Use:** Continuous KPIs, semi-annual internal audits, management review & acceptable use notices.

EVOLUTION & ROADMAP

Next Horizons in AegisAI Platform Engineering

Our forward-looking roadmap following our Release Candidate presentations to Farmacias del Ahorro, AMF, and Grupo Coppel.

Q4 2026 • NEAR TERM

Native CI/CD Shift-Left Gates

Official **GitHub Actions** and **GitLab CI Runners** to automatically block pull requests introducing prompt injection vulnerabilities, unsigned MCP manifests, or unencrypted vector storage before merging.

Q1 2027 • MEDIUM TERM

Multi-Agent Graph Auditing

Specialized auditing module for complex autonomous agent workflows (LangGraph, CrewAI, AutoGen): tool authorization boundary checks, compensating saga verification, and inter-agent memory sandboxing.

Q2 2027 • LONG TERM

Autonomous IaC Remediation

One-click automated synthesis of **Terraform Modules** and **Helm Charts** that directly apply Cloud IAP, VPC Service Controls, and Cloud Armor remediation recipes to cloud clusters.

🎯 Conclusion: Enterprise AI Assurance Built for $19.41, Auditing for $0.08–$0.30

By combining **Google AI Studio**, **Google Antigravity**, and **Vertex AI Gemini 3.8 Flash**, AegisAI proves that world-class OWASP AI-SVS & ISO/IEC 42001 assurance can be built and operated at **>99% lower cost** than legacy frontier alternatives.

Contact: opensource@aegis-ai.dev • GitHub: github.com/fjhuerta-67/AegisAI